d. Reverse proxy

e. Application server

1.4 Elements of API security

An API by its very nature defines a set of operations that a caller is permitted to use. If you don’t want a user to perform some operation, then simply exclude it from the API. So why do we need to care about API security at all?

- First, the same API may be accessible to users with distinct levels of authority; for example, with some operations allowed for only administrators or other users with a special role. The API may also be exposed to users (and bots) on the internet who should not have any access at all. Without appropriate access controls, any user can perform any action, which is likely to be undesirable. These are factors related to the environment in which the API must operate.
- Second, while each individual operation in an API may be secure on its own, combinations of operations might not be. A hardware security module (HSM) is a device used to store secret keys so that they cannot be accessed outside the device. Most HSMs offer a key-wrapping operation to export keys in an encrypted form for backup or replication. Some devices allowed the wrapped key to be passed to a decrypt operation, revealing the raw bytes of the secret key. The wrap and decrypt operations are individually secure but allowing both operations on the same object undermines the security of the device. The security of